

Web VAPT Section 01 - Lab Setup and Tool Verification

Professional documentation for Kali, Docker, DVWA access, and tool readiness validation.

Enterprise Security Assessment Lab

PROJECT AREA	Web Application Vulnerability Assessment and Penetration Testing
PRIMARY TARGET	DVWA running in local lab environment
TESTING ENVIRONMENT	Kali Linux attack machine with Docker-based vulnerable target
PREPARED BY	Jagriti Banerjee
DOCUMENT TYPE	Individual Web VAPT Attack-Section PDF

AUTHORIZED LAB TESTING ONLY

No live client data. No production systems. Screenshots and outputs must be redacted before public upload.

1. Document Purpose

This individual PDF documents the Web VAPT attack section titled 'Lab Setup and Tool Verification'. It is designed for the Enterprise Security Assessment Lab GitHub portfolio and describes the objective, tooling, commands, sanitized output, evidence mapping, security interpretation, remediation, and redaction requirements for this specific section.

This document is written as a public portfolio version. It does not contain live client data, production system details, unredacted credentials, session cookies, raw hash dumps, or destructive attack instructions.

Field	Details
Project Area	Web Application Vulnerability Assessment and Penetration Testing
Primary Target	DVWA running in a local lab environment
Testing Environment	Kali Linux attack machine with Docker-based vulnerable target
Testing Style	Reconnaissance -> Enumeration -> Manual validation -> Exploitation proof -> Evidence capture
Methodology Reference	OWASP Web Security Testing methodology, OWASP Top 10, and PTES-style workflow
Prepared By	Jagriti Banerjee

2. Section Overview

Item	Details
Section Number	01
Section Title	Web VAPT Section 01 - Lab Setup and Tool Verification
Risk / Severity Style	Operational Foundation
OWASP Mapping	Supports all OWASP test categories by validating the controlled testing environment.
Primary Evidence Count	5

2.1 Objectives

- Confirm the security testing machine is ready and isolated.
- Confirm the vulnerable target is running locally through Docker.
- Confirm DVWA is reachable before running scans or manual tests.
- Verify that every required tool is installed and usable.
- Establish clean evidence for GitHub documentation.

2.2 Tools Used

Tool	Purpose / Use in this section
Kali Linux	Dedicated security testing environment.
Docker	Runs the local vulnerable web target safely.
DVWA	Intentionally vulnerable application used for validation.
Browser	Manual verification and proof screenshots.
Nmap	Port and service discovery.
Gobuster	Directory and file enumeration.
Nikto	Web server misconfiguration scanning.
WhatWeb	Technology fingerprinting.
SQLMap	Authorized SQL Injection impact validation.
John the Ripper	Offline hash cracking demonstration.

3. Methodology and Execution Workflow

The execution workflow follows a controlled lab approach: confirm authorization and target scope, run only the tools required for the section, save outputs, validate observations manually where applicable, capture screenshots, redact sensitive values, and document findings without exaggeration.

3.1 Command Reference

```
# Confirm Kali environment
uname -a
whoami
ip -br a

# Confirm Docker target is running
docker ps

# Confirm web application is reachable
curl -I http://127.0.0.1:8081

# Confirm tool versions
nmap --version
gobuster version
nikto -Version
whatweb --version
sqlmap --version
john --version
```

3.2 Expected / Sanitized Output

```
Kali Linux environment confirmed.
Docker container for vulnerable web target confirmed.
DVWA login page reachable from browser.
Required Web VAPT tools verified.
Evidence screenshots captured for lab setup and tool readiness.
```

3.3 Validation Criteria

- The target must be the local DVWA or authorized lab environment only.
- The output must match the intended section objective.
- Evidence screenshots must clearly show the validation result or tool output.
- Any sensitive values must be blurred, cropped, removed, or replaced with placeholders.

- The section must not claim findings that are not supported by evidence.

4. Evidence Mapping

Evidence File	Evidence Type / Reason
01-kali-linux-desktop-full-screen.png	Kali Linux lab setup proof.
02-docker-containers-running.png	Docker vulnerable target running proof.
03-dvwa-login-page-browser.png	DVWA browser access proof.
04-tools-installed-version-check.png	Required tools verified.
installed.png	Setup / installation evidence.

5. Professional Security Analysis

This phase provides the foundation for the entire Web VAPT workflow. Without a clearly controlled and authorized lab, later evidence loses credibility.

Tool version checks show that the assessment was not random browsing, but a repeatable security testing process.

Docker evidence proves the target was intentionally deployed locally and not a third-party production application.

5.1 Why This Section Matters

This section matters because professional VAPT is not only about running a tool. It requires a clear objective, controlled execution, evidence capture, correct interpretation, and practical remediation. For recruiters and reviewers, this PDF shows that the work was structured, documented, and aligned with real security methodology.

5.2 Common Mistakes to Avoid

- Uploading raw outputs that expose cookies, hashes, paths, or credentials.
- Claiming production-level impact without production context.
- Reporting scanner output as a confirmed vulnerability without validation.
- Using unclear screenshots that do not show the relevant result.
- Mixing unrelated phases in one evidence file without explanation.

6. Risk Analysis

- If environment scope is unclear, a portfolio can look unsafe or unauthorized.
- If tools are not version-checked, results may be harder to reproduce.
- If Docker/network boundaries are unclear, readers may misunderstand the legality of the testing.

6.1 Real-World Impact Statement

The real-world impact depends on the affected asset, authentication context, data sensitivity, privilege level, exposed functionality, and compensating controls. Because this project uses DVWA in a lab, severity is described as a real-world context estimate rather than a formal client CVSS score.

7. Remediation and Hardening Guidance

- Use a dedicated lab machine or VM for security testing.
- Keep lab targets isolated from production networks.
- Document target URLs, ports, and container names.
- Capture tool versions before running evidence-generating tests.
- Stop or remove vulnerable containers after use if not needed.

7.1 Verification After Remediation

- 1 Re-run the original test case in the lab or development environment.
- 2 Confirm that the previous vulnerable behaviour no longer appears.
- 3 Check server logs for blocked or rejected attempts.
- 4 Capture new evidence showing the fix or defensive control.
- 5 Update the report status from validated/open to fixed/retested if applicable.

8. GitHub Redaction and Publishing Checklist

Cookies, hashes, credentials, session IDs, shell paths, database output, and private details must be redacted before public upload.

Item	Action Before Upload
PHPSESSID / Cookies	Blur or replace with <REDACTED_COOKIE>.
Password hashes	Blur or replace with <REDACTED_HASH>.
Cracked passwords	Do not publish; replace with <REDACTED_PASSWORD>.
Database dumps	Crop, blur, or summarize instead of uploading raw data.
Webshell paths/files	Do not upload shell source files; redact paths if needed.
Local usernames/paths	Blur if private or unnecessary.
Tool raw outputs	Upload only sanitized outputs or summary documents.

8.1 Safe Git Commands Before Push

```
git status
git diff --cached
git diff --cached | grep -iE "password|secret|token|cookie|PHPSESSID|hash|credential"
```

9. Conclusion

This document completes the individual Web VAPT PDF for Section 01. It documents the section objective, execution workflow, evidence mapping, professional interpretation, risk, remediation, and GitHub safety checks. The content is aligned to the actual Enterprise Security Assessment Lab Web VAPT evidence set and avoids unsupported production claims.

Legal and ethical notice: This documentation is for authorized lab testing only. Do not apply these techniques to public or third-party systems without explicit written permission.